

DOMANDE SICUREZZA

INTRO

- Come valutare la giusta difesa?
Costi-vantaggi (vedi capitolo 8)
- Descrivere gli obiettivi dell'informatica e fare un esempio di loro violazione

CRITTOGRAFIA

- È più difficile il brute forcing su password con 3 caratteri alfabetici o con 4 cifre?
Nel primo caso abbiamo $(2 \times 26)^3$ possibilità (2 perché sono maiuscole e minuscole dal momento che non è specificato). Circa 140680 possibilità. Nel secondo caso abbiamo 104 possibilità (10000). È meno difficile il secondo caso.
- Cosa fa una funzione di hash? Che caratteristiche deve avere?
La funzione di hash riassume un testo in pochi byte. La caratteristica che deve avere è quella di avere meno collisioni possibili.
- Un meccanismo di firma
Key exchange
Messaggio + chiave privata del sender (no segretezza ma autenticità)
- Perché la crittografia DES non è più considerata sicura? Quali modi di suo utilizzo potrebbero migliorare la sicurezza?
- Si spieghino le differenze fra crittografia simmetrica e crittografia asimmetrica, e le implicazioni sulla relazione fra il numero di chiavi e numero di utenti per ognuno dei due casi.
- Si spieghi il funzionamento della crittografia a chiave pubblica, indicando in particolare come si può usarla per implementare firme digitali
- Descrivere crittografia end to end e crittografia di collegamento.
- Crittografia a chiave pubblica e come usarla per firma digitale
- Firma digitale con rsa + md5

SICUREZZA APPLICAZIONI

- Se opero con codice su rom + heap è possibile avere un buffer overflow?

Nel Buffer Overflow sovrascrivo un pezzo di memoria e a seconda della zona che vado a sovrascrivere posso avere un attacco. Potrei avere nell'heap dati che altero con il Buffer Overflow ma non posso alterare gli indirizzi di ritorno perché non risiedono nell'heap ma nello stack che nel caso in esame non è presente. Quindi, nel caso in esame ho tre fattori da considerare:

- Le istruzioni che non possono essere modificate
- I dati che sono modificabili perché sono sull'heap
- Gli indirizzi di ritorno che non sono modificabili perché sono sullo stack che qui non è presente.

La risposta è quindi: sì, posso avere buffer overflow ma senza modifica degli indirizzi di ritorno.

AGGIUNTA: se il linguaggio utilizzato è un linguaggio che utilizza puntatori (ad es c), posso utilizzare un puntatore a funzione che risiedendo sull'heap dirotti l'esecuzione su codice creato dall'attaccante.

- Se in una funzione scritta in linguaggio C viene fatto overflow su stack con un'istruzione "strcpy" riscrivendo l'indirizzo di ritorno al suo chiamante, ma l'istruzione successiva alla strcpy è scritta in modo da interrompere il programma (ad esempio con "exit()"), cosa accade? Si può avere un completo att buffer overflow?
- Si descriva il funzionamento di un attacco di tipo SQL-Injection
- Si descriva il funzionamento di un attacco di tipo buffer overflow
- Come è strutturata la stringa per portare allo stack overflow

SICUREZZA SISTEMI OPERATIVI

4) "MAC" e "DAC" possono convivere? Perché?

15) Descrivere le due modalità di protezione nei sistemi operativi: ACL e "capabilities". Unix quali usa? e con quali limiti?

18) Si descriva come funziona una politica di sicurezza secondo il modello di Bell La Padula esteso con compartimenti. Si dica inoltre se tale modello definisce una politica di sicurezza di tipo DAC o MAC.

22) Si descriva il funzionamento di una Access Control List e si spieghi il concetto di "mediazione completa" nel contesto dei sistemi operativi sicuri

32) differenza tra mandatory access control e discretionary access control con esempio per ognuno

37) descrivere il modello Bell-LaPadula completo

41) Challenge/response con chiave simmetrica

SICUREZZA RETI

1) Se le risorse da difendere sono vitali è più adatto il firewall o l'IDS?

il firewall è un meccanismo di difesa attivo l'IDS è un meccanismo di difesa passivo

2) Cos'è "trusted path"? A cosa serve?

Trusted path or trusted channel — is a mechanism that provides confidence that the user is communicating with what the user intended to communicate with, ensuring that attackers can't intercept or modify whatever information is being communicated.

5) Trojan e virus possono convivere?

SI: posso avere un trojan che attacca virus a file a caso (che però non diventano trojan ma virus)

NO: il trojan è un software utile che nasconde l'attacco, il virus si aggancia automaticamente ad altri programmi che non so cosa fanno.

6) Virus e backdoors possono coesistere?

SI: posso avere virus che generano backdoors

10) Quali livelli di rete possono usare crittografia senza coinvolgere i router?

La crittografia è presente in diversi livelli: se è a livello datalink o network devo impacchettare/spacchettare i dati a ogni gateway;

se è a livello di trasporto o applicazione non è richiesto l'intervento dei router perché c'è trasparenza a ciò che sta sotto.

Se a livello network uso l'approccio tunnel, posso crittografare senza passare dal router. Il router non vede il datagramma cifrato ma un altro che reincapsula quello cifrato.

11) Cosa rallenta IDS con signature?

In IDS si esamina il traffico dati che può essere svolto attraverso due strategie: quella euristica e quella con signature; nel secondo caso, quello richiesto, si effettua un confronto con delle regole; ciò che potrebbe rallentare IDS è quindi un traffico dati eccessivo (che comporterebbe la perdita di pacchetti dal momento che non possono essere memorizzati per essere rianalizzati in seguito), o una grande lista di regole da consultare.

16) Rispetto alle possibilità di intercettare traffico su cavi ethernet, come si comportano e si differenziano gli hub e gli switch?

19) Si descriva la struttura di un pacchetto IP trasmesso usando il protocollo IPsec in modalità trasporto, spiegando che tipo di protezione si ottiene

23) Si spieghi come funziona un firewall "packet filter", e come può essere usato per proteggere una sottorete da attacchi IP-spoofing provenienti dall'esterno della sottorete stessa

25) cosa è l'attacco di ingegneria sociale (e metodo per contrastarla)

27) differenza tra firewall stateful e package inspector

30) descrivere il morris worm

34) differenza tra firewall packet filter e firewall application gateway

38) descrivere SSL e come utilizza chiave privata e pubblica

39) descrivere l'IPSEC (in particolare chiedeva il tunneling)